

HEALTH, COMPLIANCE, ESG

Updated March 12, 2021

Risk appetite and risk tolerance: what's the difference?

By: [Jean-Grégoire Manoukian](#)

As any risk professional will tell you, there is sometimes confusion and misunderstanding around terms used widely in the field of risk management.

If you want to know the exact definition of a specific risk term by researching it on the internet, you may come across multiple definitions for the same term. This can be frustrating for people who need to explain risk management concepts within their organization and implement .

If you are building your risk management framework, and need to define risk management terms, you will likely need to understand and define “Risk Appetite”. If you do a search on the internet for risk appetite, you will find many explanations that define risk appetite as the level of risk that an organization can tolerate. Evidently, many professionals use risk appetite and

risk tolerance interchangeably. This can lead to errors in your framework because: 1) both are different and distinct concepts, 2) risk appetite has a somewhat clear definition, and is not just a fancier synonym for risk tolerance, 3) risk tolerance is itself not well defined, meaning there are different interpretations of what it means.

In this post, we will demystify risk appetite and risk tolerance, with the hope that it helps you understand both concepts, so that you can integrate them in your framework.

Risk Appetite Is the General Level of Risk You Accept

The first thing to know about risk appetite is that...it's one of the first things that you must determine. Why? Because determining risk appetite will help you determine the amount of risk you're willing to "live" with, and how much risk you need to manage. Risk appetite is the **level of risk that an organization is willing to accept while pursuing its objectives, and before any action is determined to be necessary in order to reduce the risk.** [ISO Guide 73:2009 Risk Management – Vocabulary](#) defines risk appetite as the **"amount and type of risk that an organization is willing to pursue or retain."** Risk appetite allows organizations to determine how much they are willing to take risks (including financial and operational impacts) in order to innovate in pursuit of objectives.

Risk appetite can vary based on a number of factors, such as: **1) industry, 2) company culture, 3) competitors, 4) the nature of the objectives pursued** (e.g. how aggressive they are), and **5) the financial strength and capabilities of the organization** (i.e. the more resources a company has, the more willing it may be to accept risks and the costs associated to them). It's also worth noting that risk appetite can **change over time**. It's always a good idea to assess risks against risk criteria periodically or continuously (e.g. once or twice annually, or daily in specific risk scenarios), depending on the circumstances, available resources, skills, technologies or systems.

Risk Tolerance Is More Granular and Affects Individual Risks

When I started writing this post, the introduction and the section on risk appetite went smoothly. Then I got to this section on risk tolerance and I got stuck. Why? Because after researching the concept on the internet, I came across three distinct definitions, four if I take into account the fact that one of the definitions can come in two varieties, so about 3.5

definitions for the same concept! So I gave up trying to figure this one on my own, and turned to Johannes Swanepoel at Standard Model Partners, a premiere provider of Governance, Risk Management, and Compliance (GRC) products and services. Standard Model Partners is an Enablon Partner and Gold Sponsor at .

Swanepoel gave very interesting feedback. Even though risk tolerance and risk appetite are defined, they seem to be interpreted and used inconsistently between risk management programs, he said. Researching their definitions gives you people's interpretations. Therefore, he only uses **terms included in the ISO 31000:2009 Risk Management standard**, because these terms are subject to rigorous review by ISO members, and ISO can only include a term if consensus is formed on its meaning among its members. While ISO 31000 does not include a definition of risk tolerance or risk appetite, [ISO Guide 73:2009 Risk Management – Vocabulary](#) defines risk tolerance as “**an organization's or stakeholder's readiness to bear the risk after risk treatment in order to achieve its objectives.**”

In addition, according to COSO's “Strengthening Enterprise Risk Management for Strategic Advantage”, **risk tolerance “reflects the acceptable variation in outcomes related to specific performance measures linked to objectives the entity seeks to achieve”**, while risk appetite is defined as “a broad-based description of the desired level of risk that an entity will take in pursuit of its mission”.

The Relationship Between Risk Tolerance and Risk Appetite

For Swanepoel, risk tolerance is the level of risk that an organization can accept **per individual risk**, whereas risk appetite is the **total risk that the organization can bear in a given risk profile**, usually expressed in aggregate. Risk tolerance is related to the **acceptance of the outcomes of a risk** should they occur, and having the right resources and controls in place to absorb or “tolerate” the given risk, expressed in qualitative and/or quantitative risk criteria. On the other hand, risk appetite is related to the **longer term strategy of what needs to be achieved** and the resources available to achieve it, expressed in quantitative criteria.

As mentioned earlier, ISO31000:2009 includes neither of the two terms because ISO says that “publication as an International Standard requires approval by at least 75% of the member bodies casting a vote.” So when referencing ISO31000:2009, “**Risk Attitude**” is used.

ISO31000:2009 defines risk attitude as “**an organization’s approach to assess and eventually pursue, retain, take or turn away from risk.**”

ISO/TR 31004 takes this a step further by explaining the importance of risk criteria in the measurement of an organization’s risk attitude. When implementing a risk framework, it states: “Appropriate risk criteria should be established. **Risk criteria need to be consistent with the objectives of the organization and aligned with its risk attitude.** If the objectives change, the risk criteria need to be adjusted accordingly. It’s important for effective risk management that the **risk criteria are developed to reflect the organization’s risk attitude and objectives.**”

In conclusion, Swanepoel’s advice is to **stick with terms that are defined by ISO standards.** If a term is not defined by an ISO standard, it will simply invite others to provide their own interpretations, which results in more confusion than the initial confusion you were trying to clarify in the first place. This then increases the risk of being misunderstood, and if you have a low tolerance for that, it’s better to avoid the risk altogether.

[Jean-Grégoire Manoukian](#)

Content Thought Leader - Wolters Kluwer Enablon

Jean-Grégoire Manoukian is Content Thought Leader at Wolters Kluwer Enablon. He’s responsible for thought leadership, content creation and the management of articles and social media activities. JG started at Enablon in 2014 as Content Marketing Manager and has more than 25 years of experience, including many years as a product manager for chemical management and product stewardship solutions. He also worked as a product marketing manager in the telecommunications industry.

EXPLORE RELATED TOPICS

RISK MANAGEMENT

CASE STUDY

Learn how one of the largest Banking Groups in the world standardized risk management practices across its operations.

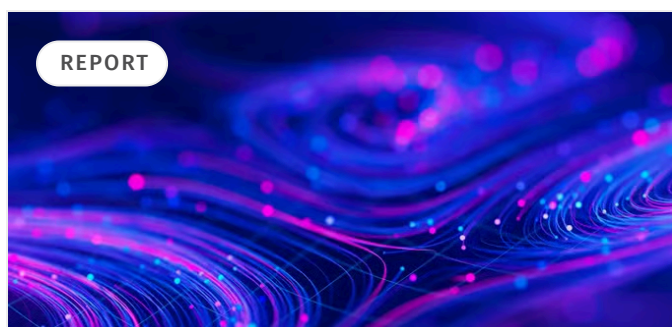
[Read Case Study →](#)

RISK MANAGEMENT SOFTWARE

Systemize your organization's risk management processes

[> Learn more](#)

Related Insights

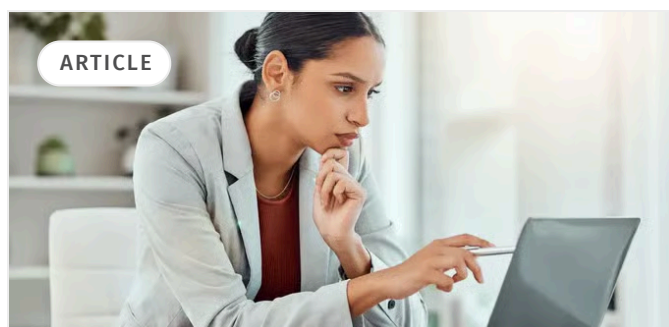


REPORT

COMPLIANCE June 10, 2026

AI in audit data analysis: Risks, limitations, and best practices

AI in audit data analysis explores the benefits, risks, and limitations of GenAI, highlighting when auditors should use AI, avoid it, and apply human oversight for accurate, reliable results.

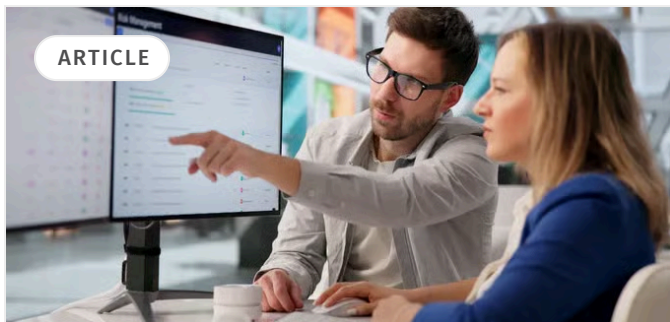


ARTICLE

COMPLIANCE June 10, 2026

Data compliance: Everything you need to know

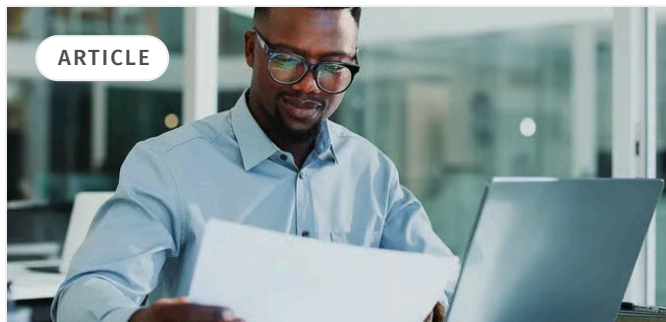
Strengthen your data compliance strategy with practical steps to reduce risk, protect data, and meet evolving global regulations with confidence.

[Learn More →](#)[Learn More →](#)

COMPLIANCE June 10, 2026

The IIA Cybersecurity Topical Requirement: What internal auditors need to know

Learn how the IIA's cybersecurity topical requirement is reshaping cybersecurity audits through governance, resilience, risk alignment, and modern assurance practices.

[Learn More →](#)

COMPLIANCE June 04, 2026

Understanding the relationship between NIST CSF and ISO 27001

Learn about the similarities, differences, and integration opportunities between NIST CSF and ISO 27001 to choose the right path or combine both for stronger security governance and regulatory alignment.

[Learn More →](#)

[Home](#) > [Expert Insights](#) > **Risk appetite and risk tolerance: what's the difference?**

[About Wolters Kluwer](#)[Strategy](#)[Organization](#)[Management](#)[News & Press Releases](#)[Solutions Directory](#)[Health](#)[Tax & Accounting](#)[Corporate Performance & ESG](#)[Financial & Corporate Compliance](#)

Events

Legal & Regulatory

Expert Insights

Careers

Investors

Site Owner

Follow Wolters Kluwer



When you have to be right

Terms of Use Privacy & Cookies Manage Cookie Preferences

© 2026 Wolters Kluwer N.V. and/or its subsidiaries. All rights reserved.